SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A1-Threat Intelligence Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.No	192411213	**Name**	Lakshmipathi Deepthi
Faculty	Dr.V.Parthipan	**Slot**	A

Instructions: Answer all questions. Each question carries 5 marks. Support answers with examples and diagrams where appropriate.

Code of Conduct:

I Lakshmipathi Deepthi(192411213) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of Student

L Deepthi

Questions

Q1. Malware [5 Marks]

Define malware and explain any four types of malware (virus, worm, trojan, ransomware, spyware). For each type, state how it spreads and one impact on the victim.

Q2. Phishing [5 Marks]

Describe how a phishing attack is carried out. Differentiate between spear phishing, whaling and vishing, and list three measures an organisation can adopt to reduce phishing risk.

Q3. DoS and DDoS [5 Marks]

Distinguish between a Denial of Service (DoS) attack and a Distributed Denial of Service (DDoS) attack. Explain the working of a SYN flood and outline two mitigation techniques.

Q4. Man-in-the-Middle Attacks [5 Marks]

What is a Man-in-the-Middle (MITM) attack? Explain two techniques used to carry it out (for example ARP poisoning, rogue Wi-Fi access point, SSL stripping) and state how encryption helps defend against it.

Q5. Spoofing and Sniffing [5 Marks]

Compare spoofing and sniffing. Explain IP spoofing and ARP spoofing with an example each, and describe how packet sniffers such as Wireshark can be used both maliciously and legitimately.

Q6. Vulnerability Assessment [5 Marks]

Explain the vulnerability assessment process. Describe its main phases, and differentiate between vulnerability assessment and penetration testing. Name two commonly used scanning tools.

Q7. Vulnerability Scoring [5 Marks]

What are CVE and CVSS? Explain how CVSS scores help in prioritising vulnerabilities and why a high CVSS score alone may not decide the order of patching.

Q8. Threat Data Sources and OSINT [5 Marks]

Discuss the main sources of threat data (internal, external, open-source and commercial). Define Open-Source Intelligence (OSINT) and describe three OSINT sources or tools used in threat intelligence gathering.

Q9. Indicators of Compromise (IoCs) [5 Marks]

What are Indicators of Compromise (IoCs)? Classify them into network-based, host-based and file-based indicators with two examples of each, and explain how a security team uses IoCs during incident response.

Q10. Threat Feeds [5 Marks]

Explain what a threat intelligence feed is. Describe the common feed formats and sharing standards (STIX/TAXII), list two advantages and two limitations of using threat feeds, and name two example feeds.

Marking Scheme (for evaluator)

Q.No	Expected points and mark distribution (total 5)
1	Definition (1); four types with spread method and impact (4 x 1 = 4).
2	Attack flow (1.5); three variants differentiated (1.5); three countermeasures (2).
3	DoS vs DDoS (1.5); SYN flood working (1.5); two mitigations such as rate limiting, SYN cookies, CDN/scrubbing, blackhole routing (2).
4	Definition and interception concept (1); two techniques (2); defences such as TLS, HSTS, certificate validation, VPN (2).
5	Comparison (1); IP and ARP spoofing with examples (2); sniffer dual use (1.5); one countermeasure (0.5).
6	Phases: asset discovery, scanning, analysis and prioritisation, reporting, remediation (2); VA vs pen test (2); two tools such as Nessus, OpenVAS, Qualys (1).
7	CVE meaning (1); CVSS meaning and severity ratings (1.5); role in prioritisation (1.5); context factors such as exploitability and asset criticality (1).
8	Threat data source categories (2); OSINT definition (1); three OSINT sources or tools such as Shodan, VirusTotal, WHOIS, social media, dark web monitoring (2).
9	Definition (1); classification with examples (3); use in detection and response (1).
10	Definition (1); STIX/TAXII or similar formats (1.5); two advantages and two limitations

ANSWERS

Q1. Malware

Definition: Malware (malicious software) is software designed to damage systems, steal information, disrupt operations, or gain unauthorised access.
Four types of malware are:

1. Virus: A virus attaches itself to a legitimate file or program and spreads when the infected file is executed. Impact: It may corrupt or delete files.
2. Worm: A worm spreads automatically across networks by exploiting security weaknesses. Impact: It consumes network bandwidth and slows down systems.
3. Trojan Horse: A Trojan disguises itself as legitimate software and is installed when a user runs it. Impact: It can allow attackers to access confidential information.
4. Ransomware: Ransomware commonly spreads through malicious email attachments, compromised websites, or exploited vulnerabilities. Impact: It encrypts files and demands payment to restore access.

Q2. Phishing

Phishing is a cyberattack in which attackers impersonate trusted individuals or organisations to trick users into revealing sensitive information or installing malware.
How a phishing attack works:

1. The attacker creates a fake email, message, or website.
2. The message is sent to the victim, often creating urgency or fear.
3. The victim clicks a malicious link, opens an attachment, or submits personal information.
4. The attacker steals credentials, financial information, or gains access to the system.

Types of phishing:

- Spear phishing: A targeted attack against a specific person or organisation using personalised information.
- Whaling: A targeted phishing attack against senior executives or other

high-level officials.

- Vishing: Voice phishing conducted through phone calls or internet-based voice communication.

Three preventive measures:

1. Conduct regular cybersecurity and phishing-awareness training.
2. Enable multi-factor authentication (MFA) and use strong passwords.
3. Implement email filtering, anti-phishing protection, and verification of suspicious requests.

Q3. DoS and DDoS

Denial of Service (DoS) is an attack that overwhelms a server or network with excessive requests or traffic, making the service unavailable to legitimate users.
Distributed Denial of Service (DDoS) is an attack that uses multiple compromised devices to flood a target with traffic simultaneously.

DoS	**DDoS**
Usually originates from one system or source.	Originates from multiple distributed systems.
Comparatively easier to identify and block.	More difficult to block because traffic comes from many sources.
Generally has a smaller traffic distribution.	Can generate large volumes of distributed traffic.

Working of a SYN flood:

1. The attacker sends many TCP SYN connection requests to a server.
2. The server responds with SYN-ACK messages and waits for the final ACK.
3. The attacker leaves many connections incomplete, consuming server resources.
4. Legitimate users may be unable to establish connections.

Two mitigation techniques:

1. SYN cookies: Allow the server to handle connection requests without allocating full connection state immediately.
2. Rate limiting and traffic filtering: Limit excessive connection requests and filter suspicious traffic. Large-scale attacks may also require DDoS scrubbing services or a CDN.

Q4. Man-in-the-Middle Attacks

A Man-in-the-Middle (MITM) attack occurs when an attacker secretly intercepts or potentially modifies communication between two parties who believe they are communicating directly.

Two techniques:

1. ARP poisoning: An attacker sends false ARP messages on a local network to associate the attacker's MAC address with another device's IP address. This can redirect traffic through the attacker.
2. Rogue Wi-Fi access point: An attacker creates a fake wireless hotspot that resembles a trusted network. Users who connect may expose their traffic or credentials if adequate protections are absent.

How encryption helps:

- HTTPS/TLS: Encrypts communication and helps prevent attackers from reading or modifying data in transit.
- Certificate validation: Helps verify that the server is genuine.
- HSTS: Instructs browsers to use HTTPS for supported websites.
- VPN: Provides an encrypted tunnel between the device and the VPN endpoint, especially useful on untrusted networks.

Encryption is effective when certificates are properly validated and users do not bypass security warnings.

Q5. Spoofing and Sniffing

Spoofing means falsifying an identity or address to impersonate another device or user. Sniffing means capturing and analysing network traffic to observe communication.

Spoofing	**Sniffing**
Involves falsifying identity or network	Involves monitoring and capturing packets.

information.	
Used to impersonate systems or redirect traffic.	Used to analyse communication and identify information.
Example: IP address spoofing.	Example: Capturing network packets using Wireshark.

IP spoofing: An attacker changes the source IP address in packets to make them appear to originate from another system. For example, an attacker may send malicious traffic with a forged source IP address to hide its origin or bypass weak IP-based filtering.

ARP spoofing: An attacker sends forged ARP messages to associate their MAC address with a legitimate device's IP address. For example, a victim's computer may send network traffic to the attacker's machine instead of the intended gateway.

Packet sniffers such as Wireshark:

- Malicious use: Attackers may capture unencrypted passwords, session information, or confidential data.
- Legitimate use: Network administrators use Wireshark to troubleshoot connectivity issues, inspect protocols, detect unusual traffic, and investigate security incidents.

Countermeasure: Use HTTPS/TLS, secure network configurations, and network monitoring to reduce the risks of sniffing and spoofing.

Q6. Vulnerability Assessment

Vulnerability assessment (VA) is a systematic process of identifying, analysing, prioritising, and reporting security weaknesses in computer systems, applications, and networks.

Main phases:

1. Asset discovery: Identify the systems, applications, devices, and network assets to be assessed.
2. Scanning: Use automated tools to identify known vulnerabilities, outdated software, and configuration weaknesses.
3. Analysis and prioritisation: Validate findings where possible and rank vulnerabilities according to severity and risk.
4. Reporting: Document vulnerabilities, their impacts, severity levels, and recommended solutions.

5. Remediation and verification: Apply patches or configuration changes and rescan to confirm that weaknesses have been addressed.

Vulnerability assessment vs penetration testing:

Vulnerability Assessment	**Penetration Testing**
Identifies and prioritises security weaknesses.	Attempts to exploit selected weaknesses within an authorised scope.
Often uses automated scanning tools.	Uses manual testing and tools to demonstrate real-world attack paths.
Provides a broad view of potential vulnerabilities.	Demonstrates how vulnerabilities could be exploited and what impact they may cause.

Two commonly used tools:

- Nessus: Scans systems for vulnerabilities and misconfigurations.
- OpenVAS: An open-source vulnerability scanning solution.

Q7. Vulnerability Scoring

CVE (Common Vulnerabilities and Exposures): CVE is a system of publicly identifying and cataloguing known cybersecurity vulnerabilities using unique identifiers, such as CVE-2024-12345.

CVSS (Common Vulnerability Scoring System): CVSS is a standard framework for assessing the technical severity of vulnerabilities on a scale from 0.0 to 10.0.

CVSS severity ratings:

Score	**Severity**
0.0	None
0.1–3.9	Low
4.0–6.9	Medium
7.0–8.9	High
9.0–10.0	Critical

How CVSS helps prioritisation:

- Helps security teams compare vulnerability severity consistently.
- Highlights vulnerabilities that may cause serious technical damage.
- Supports patch planning and risk reporting.

Why a high CVSS score alone is insufficient:

Patching priority also depends on whether the vulnerability is actively exploited, whether an exploit is publicly available, whether the affected system is exposed

to the internet, the criticality of the asset, and the availability of compensating controls.

For example, an actively exploited high-severity vulnerability on a public-facing payment server may require more urgent patching than a critical-severity vulnerability affecting an isolated test system.

Q8. Threat Data Sources and OSINT

Threat intelligence helps organisations understand potential attackers, malicious activities, vulnerabilities, and emerging cybersecurity risks.

Main sources of threat data:

1. Internal sources: Firewall logs, antivirus alerts, endpoint detection systems, and incident reports generated within an organisation.
2. External sources: Information from security vendors, industry sharing groups, government agencies, and other organisations.
3. Open-source sources: Publicly available security reports, vulnerability databases, security blogs, and threat research.
4. Commercial sources: Paid threat intelligence platforms that provide curated threat feeds, analysis, and alerts.

Open-Source Intelligence (OSINT) is the process of collecting and analysing information from publicly available sources to produce useful intelligence.

Three OSINT sources or tools:

1. Shodan: Helps discover internet-connected devices and identify potentially exposed services.
2. VirusTotal: Analyses files, URLs, domains, and IP addresses using multiple security detection engines and other intelligence sources.
3. WHOIS: Provides domain registration information that may help investigate suspicious domains and identify registration patterns.

These sources help security teams identify suspicious infrastructure, investigate threats, and strengthen security monitoring. Information should be verified because public data may be incomplete or outdated.

Q9. Indicators of Compromise (IoCs)

Indicators of Compromise (IoCs) are observable signs that may indicate a system or network has been compromised by malicious activity.

Classification of IoCs:

Type	Description	Two examples
Network-based	Indicators observed in network traffic or connections.	Communication with a known malicious IP address; DNS requests to a known malicious domain.
Host-based	Signs of suspicious activity on a computer or server.	Unusual registry modifications; an unexpected suspicious process running on the system.
File-based	Characteristics of suspicious or malicious files.	A known malicious file hash; a suspicious executable file found in an unusual directory.

How security teams use IoCs during incident response:

1. Detection: Search security logs and monitoring systems for known IoCs.
2. Investigation: Identify affected systems and determine the possible scope of the incident.
3. Containment: Block malicious IP addresses or domains and isolate infected devices.
4. Eradication and recovery: Remove malicious files, close the attack path, and restore affected systems.
5. Prevention: Update detection rules and use lessons learned to reduce future attacks.

IoCs help detect and investigate attacks, but they should be combined with behavioural analysis because attackers can change IP addresses, domains, and file hashes.

Q10. Threat Feeds

A threat intelligence feed is a continuously updated stream of information about cyber threats, such as malicious IP addresses, suspicious domains, file hashes, phishing URLs, and known attack techniques.

Common formats and sharing standards:

1. CSV and JSON: Simple formats used to exchange lists of indicators and related information.
2. STIX (Structured Threat Information Expression): A standard language for representing and sharing structured cyber threat intelligence.
3. TAXII (Trusted Automated Exchange of Intelligence Information): A protocol for exchanging threat intelligence, including STIX data, between systems.
4. OpenIOC: A framework for describing indicators of compromise in a structured form.

Advantages of threat feeds:

1. Early threat detection: Helps identify known malicious infrastructure and suspicious activity.
2. Automation: Allows security tools such as SIEMs, firewalls, and endpoint protection systems to incorporate threat indicators into monitoring and blocking rules.

Limitations of threat feeds:

1. False positives and outdated data: Some indicators may be inaccurate, expired, or no longer malicious.
2. Limited context: An indicator alone may not explain the attack method, target, or actual risk to the organisation.

Two example threat intelligence feeds:

- AlienVault Open Threat Exchange (OTX): A platform for sharing threat intelligence and indicators.
- abuse.ch: Provides threat intelligence resources and feeds related to malware, botnets, and malicious infrastructure.

Conclusion:

Threat feeds improve security monitoring and incident response by providing timely information about known threats. However, organisations should validate indicators, consider their own environment, and combine threat feeds with other security controls.